

Relatório de Auditoria de Segurança

SIMUT — Sistema Integrado de Monitoramento Universal e Telemetria

Data: 29/08/2026

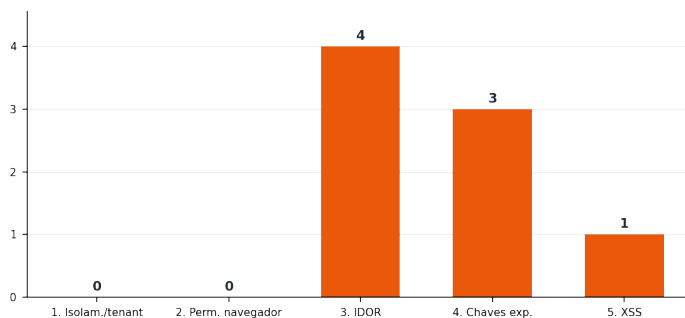
Versão auditada: v2.3.6-beta (commit 4586733)

Escopo: Firmware embarcado (C++/Arduino) + Web UI + OTA/MQTT/Telemetria + CI/Docker + histórico git

Metodologia: Cinco categorias mapeadas para a stack: isolamento de inquilino → RBAC por bitmask de permissão por sessão; permissão no navegador → cruzamento dos gates do frontend (WebUI.h) com os handlers do backend; IDOR → rotas por path/arquivo (download/delete/ls/upload/mkdir/restore); chaves expostas → código + configs + CI + Docker + histórico git; XSS → sinks innerHTML/HTML dinâmico no frontend e backend.

Resumo executivo

Foram identificados **8 achados** verificados no código real: **2 alta**, **1 média**, **4 baixa** e **1 informativa** (nenhuma crítica). O principal tema é a **guarda da pasta /config** (loja de credenciais e chaves TLS) aplicada apenas à leitura (*/download*) e ausente nos caminhos de escrita e exclusão — */api/delete*, */api/upload* e */api/restore?op=apply*. O restante da superfície é notavelmente robusto: RBAC por bitmask em todas as rotas, modelo de dois níveis de privilégio, lockout exponencial de login, sanitização de caminhos, escape de HTML no frontend e gate de segredos no CI.



Paleta: crítica ■ · alta ■ · média ■ · baixa ■ · informativa ■ · ponto forte ■

Pontos fortes e pontos fracos

Pontos fortes (o que está protegido, com evidência)

- ✓ **Autorização em todas as rotas.** Todos os handlers de `src/WebManager_*.cpp` chamam `getAuthPerms()` e testam o bit correto; a matriz é documentada em `docs/AUTHORIZATION.md` e enforçada por `tools/check_authz.py` no CI (nenhuma rota sem gate, exceto as allowlistadas com razão).
- ✓ **Dois níveis de privilégio.** `/api/commit_all` recusa perms acima de `PERM_ALL_BITS (0x03FF)`; `/api/backup`, `/api/restore?op=stage` e `/api/ota/apply` exigem `perms == PERM_FULL_ADMIN`. Web admin não lê backup nem grava firmware (`WebManager_Commit.cpp:1079`; `WebManager_Ota.cpp`).
- ✓ **Login endurecido.** Nonce CSRF consumido atomicamente, lockout exponencial por IP com slots sticky, senhas HMAC-SHA256 com salt aleatório + pepper do chip (v1), migração legada e `secureCompare` em tempo constante (`WebManager_Auth.cpp` / `StorageManager.cpp`).
- ✓ **Sanitização de caminho (leitura).** `/download`, `/api/ls`, `/api/upload` e `/api/mkdir` rejeitam `'..'`, `'%'` e caracteres hostis; `isSafeUploadFilename/isSafeDirPath` com allowlist; `/download` recusa `/config` via `isSecretFsPath` (`WebManager_Files.cpp:59`).
- ✓ **Anti-XSS.** Frontend usa `escHtml/escAttr` em todos os templates com dado de operador; backend usa `jsonEscape/jsonEscapeFilename`; nomes validados por `isValidName` (`WebUI.h:6992/7007`; M-7).
- ✓ **Gate de segredos + CI.** `tools/scan_secrets.sh` (roda no GitHub Actions) bloqueia `.pem/.key/.bkp`, chaves privadas por conteúdo e credenciais literais; fuzz (`libFuzzer`) e `cppcheck` em jobs separados.
- ✓ **Config protegida em repouso.** Campos sensíveis com XOR keystream (`SHA-256(chip_id+domínio)`), CRC32 + dual-bank, senha inicial do admin apenas em RAM e zerada após uso.
- ✓ **Histórico git limpo.** Nenhuma chave privada, `.bkp` ou credencial real commitada (scan em 895 commits); gate de segredos passa limpo.

Pontos fracos (riscos centrais)

- Escrita/exclusão sobre `/config` sem guarda (ACH-01..04): a proteção da loja de credenciais cobre leitura, mas não mutação.
- Confiança no canal: o login envia SHA-256 da senha (pass-the-hash) e, sem TLS provisionado, cookies/payloads trafegam em claro em rede não confiável (reconhecido em `SECURITY.md` como fora de escopo).
- Sem assinatura de firmware: OTA valida apenas CRC/size, não autentica a origem do binário (responsabilidade do operador).
- Credenciais padrão (`viewer/viewer`, PIN 1234) e AP de setup aberto — mitigados por troca forçada e timeout, mas exigem disciplina do operador.

Achados detalhados por categoria

Severidade | Arquivo:linha | Descrição. Os trechos completos de código, impacto e correção estão nas issues (seção final).

Sev.	Categoria	Arquivo:linha	Descrição
Alta	3. IDOR	src/WebManager_Files .cpp:85-129	DELETE /api/delete aceita qualquer caminho — apaga /config (credenciais) sem a guarda isSecretFsPath O handler de exclusao valida o caminho apenas contra isProtectedFsPath (que protege somente os README.txt de pastas). Diferente do download (linha 59, que rejeita .., % e isSecretFsPath), aqui nao ha rejeicao de traversal nem da pasta /config . Um usuario com PERM_FILE_DELETE (0x80) consegue apagar /config/system.bin (loja de credenciais + hashes), /config/web_key.pem e /config/web_cert.pem .
Alta	3. IDOR	src/WebManager_Files .cpp:359-437	UPLOAD /api/upload permite gravar sob /config — sobrescreve system.bin / planta certificado TLS A montagem do caminho final de upload (uploadDir + nome do arquivo) nao aplica isSecretFsPath . isSafeUploadFilename permite o caractere /, e o campo uploadDir e aceito como /config . So /calib.csv e remapeado (linha 432). Um usuario com PERM_FILE_UPLOAD (0x40) pode sobrescrever /config/system.bin (corrompe a config -> factory-reset no proximo boot) ou gravar web_cert.pem/web_key.pem proprios (passa a servir TLS com certificado do atacante apos reboot, viabilizando MITM do trafego administrativo).
Média	3. IDOR	src/ota/restore.cpp: 27-36	RESTORE /api/restore?op=apply valida '..' mas nao /config — .bkp malicioso grava em /config path_is_safe rejeita apenas caminhos que nao comecam com '/' e a sequencia '..'. Nao ha checagem de isSecretFsPath , entao um backup .bkp forjado pode nomear /config/system.bin como destino. O vinculo por chip_id nao e uma barreira real: o chip_id e o mesmo valor exposto como serial em GET /api/config (src/WebManager_Api.cpp:203-204, PERM_SYS_CONFIG).
Baixa	3. IDOR	src/WebManager_Files .cpp:131-171	LIST /api/lis lista o conteudo de /config (nomes de arquivos sensiveis) handleApiLis valida '..' e '%' mas nao isSecretFsPath , entao ?dir=/config enumera os nomes dos arquivos da pasta de segredos (system.bin, web_cert.pem, web_key.pem). Divulgacao minima de informacao, mas revela exatamente o que ACH-01/02 permitem apagar/sobrescrever.
Baixa	4. Chaves expostas	tools/web_test_suite .py:57 · tools/pico_test_suite.py:301 · tools/alarm_mqtt_test.py:47 · tools/validate_top_pin_alarm.py:40 · tools/telemetry_bench/phase_mqtt.py:239	Credenciais de bancada/teste hardcoded em scripts (Wt3st!suite#2026, Pico!Test123, Alarm!Test2026, benchuser/benchsecret) Diversos scripts em tools/ trazem senhas literais de contas de bancada. Elas estao documentadas como test-only em tools/.secretscan-allow e o gate scan_secrets.sh as libera de proposito. Nao sao compiladas no firmware. O risco e o reuso : se um operador criar essas mesmas credenciais em um dispositivo real, qualquer leitor do repositorio publico (github.com/angeloINTJ/simut) tem o segredo.
Baixa	4. Chaves expostas	src/StorageManager.cpp:506-511 · src/StorageManager.cpp:556	Credenciais padrao documentadas: usuario viewer/viewer e PIN de display 1234 O firmware cria a conta viewer com senha viewer (PERM_DASHBOARD PERM_HISTORY) e o PIN de display 1234 . Ambos tem flag de troca obrigatoria no primeiro uso (mustChangePassword / mustChangePin) e estao documentados em SECURITY.md §2. O PIN 1234 e deliberadamente trivial (protege so contra toque acidental).
Baixa	5. XSS	WebUI.h:6984 · src/WebManager_Api.cpp:452-512	Stored XSS via pacote de idioma: applyLang injeta @WEBDICT (de .Ing enviavel) em innerHTML sem sanitizar O dicionario de UI e servido por /api/lang (sem autenticao) a partir do bloco @WEBDICT do arquivo .Ing ativo — que e enviavel via /files (PERM_FILE_UPLOAD). applyLang escreve esses valores com el.innerHTML = text sem passar por escHtml . Um operador com PERM_FILE_UPLOAD que suba um .Ing malicioso e o torne ativo executa JavaScript no navegador de todos os usuarios (inclusive admin). O resto do frontend usa escHtml/escAttr corretamente (finding M-7).

Sev.	Categoria	Arquivo:linha	Descrição
Info	4. Chaves expostas	src/NetworkManager.c pp: 97-98	Access Point de setup aberto (sem senha) com SSID previsível _SETUP No modo AP de configuracao/recovery, o AP e criado sem senha (WiFi.softAP) e com SSID derivado do nome do dispositivo (padrao simut_SETUP). O web server continua exigindo login (senha admin aleatoria), e o AP expira em 15 min (AP_MODE_TIMEOUT_MS) retornando a STA quando ha SSID configurado. Superficie de setup/recovery, por design.

Recomendações priorizadas

[P1] Aplicar a guarda de `/config` (`isSecretFsPath` + rejeição de `'../'%'`) em `/api/delete`, `/api/upload` e `path_is_safe` do `restore`, e recusar a listagem de `/config` em `/api/lis`. É uma correção local, de alto valor, e fecha o único cluster de alta severidade.

[P2] Cobrir o gap com um teste de regressão em `tools/check_authz.py` ou novo script: para cada rota de mutação de arquivo, assertar que `/config` é recusado (`delete/upload/restore`).

[P3] Escapar o texto do dicionário de idioma (`escHtml`) em `applyLang`, ou servir o dicionário de fonte não gravável (`flash`), eliminando o `stored-XSS` residual via `.lng`.

[P4] Substituir as credenciais de bancada literais por `rig_secrets.py/ambiente` em todos os scripts de `tools/` e enxugar a `allowlist.secretsan-allow`.

[P5] Avaliar assinar o firmware OTA (ou ao menos documentar um hash de release) e, opcionalmente, proteger o AP de setup com WPA2 derivada do serial.

[P6] Reforçar a orientação ao operador sobre rede isolada/VPN, já que o transporte sem TLS e o `pass-the-hash` do login são limitações assumidas.

Issues para o GitHub

Cada bloco abaixo é uma issue completa em Markdown, pronta para copiar e colar.

```
--- ISSUE 1 ---
# [Segurança] Caminhos de escrita/exclusão de /config não aplicam a guarda isSecretFsPath (delete, upload, restore, ls)
> **Labels sugeridas:** security, severity: high

**Descrição do problema / por que é explorável**

As rotas de mutação de arquivos não protegem a pasta **/config** (loja de credenciais: system.bin com hashes de senha)

**Evidência (arquivo:linha + trecho)**

- **ACH-01** src/WebManager_Files.cpp:85-129 – handleDelete valida apenas isProtectedFsPath (README.txt) e chama LittleFS
- **ACH-02** src/WebManager_Files.cpp:359-437 – handleUploadData monta finalPath a partir de uploadDir sem checar /config
- **ACH-03** src/ota/restore.cpp:27-36 – path_is_safe rejeita .. mas não /config; o chip_id de vínculo é exposto como chip_id
- **ACH-04** src/WebManager_Files.cpp:131-171 – handleApiLs lista /config.

**Impacto**

Apagar /config/system.bin força factory-reset (perda de config/usuários/WiFi/telemetria); apagar/substituir web_key.per

**Sugestão de correção**

Aplicar a mesma guarda de /download (linha 59) em todos os caminhos de mutação: rejeitar isSecretFsPath(path) + .. e %

**Critérios de aceite**

- [ ] POST /api/delete file=/config/system.bin → 403 (hoje: apaga).
- [ ] POST /api/upload com uploadDir=/config → rejeitado.
- [ ] POST /api/restore?op=apply com entrada /config/... → PATH_INVALID.
- [ ] GET /api/ls?dir=/config → recusado.
- [ ] Teste de regressão no CI cobrindo os quatro casos.
--- FIM ISSUE 1 ---

--- ISSUE 2 ---
# [Segurança] Credenciais de bancada hardcoded em tools/ (reuso possível em produção)
> **Labels sugeridas:** security, severity: low

**Descrição do problema / por que é explorável**

Scripts de bancada em tools/ contêm senhas literais de contas de teste (Wt3st!suite#2026, Pico!Test123, Alarm!Test2026)

**Evidência (arquivo:linha + trecho)**

- tools/web_test_suite.py:57 TEST_PASS = 'Wt3st!suite#2026'
- tools/pico_test_suite.py:301 API_PASS = 'Pico!Test123'
- tools/alarm_mqtt_test.py:47 TEST_PASS = 'Alarm!Test2026'
- tools/telemetry_bench/phase_mqtt.py:239 'm_user':'benchuser','m_pass':'benchsecret'

**Impacto**

Comprometimento de conta/device caso haja reuso das credenciais de teste em produção.

**Sugestão de correção**

Migrar todos os scripts para rig_secrets.py (gitignored) ou variáveis de ambiente SIMUT_WEB_USER/SIMUT_WEB_PASS, e redig

**Critérios de aceite**

- [ ] Nenhum script em tools/ lê senha literal de conta web; todos usam rig_secrets/env.
- [ ] ./tools/scan_secrets.sh continua limpo.
- [ ] Documentação de bancada explica como criar rig_secrets.py.
--- FIM ISSUE 2 ---

--- ISSUE 3 ---
# [Segurança] Stored XSS via pacote de idioma (.lng → applyLang innerHTML sem sanitização)
> **Labels sugeridas:** security, severity: low

**Descrição do problema / por que é explorável**

applyLang (WebUI.h:6984) escreve o dicionário de UI (dict[lang][key]) com el.innerHTML = text sem passar por escHtml.
```

****Evidência (arquivo:linha + trecho)****

```
- WebUI.h:6984 window.applyLang = ... else el.innerHTML = text;  
- src/WebManager_Api.cpp:452-512 handleApiLang serve o @WEBDICT sem auth.
```

****Impacto****

Execução de script no contexto administrativo, condicionada a um ator já privilegiado (upload de .lng).

****Sugestão de correção****

Aplicar escHtml(text) no applyLang, ou servir o dicionário a partir de fonte não gravável (pacote embutido em flash, c

****Critérios de aceite****

```
- [ ] Um .lng com <img src=x onerror=...> num valor de chave existente não executa.  
- [ ] Teste automatizado de sanitização do dicionário.  
--- FIM ISSUE 3 ---
```

--- ISSUE 4 ---

```
# [Segurança] Hardening de defaults e superfície de setup (viewer/viewer, PIN 1234, AP aberto)  
> **Labels sugeridas:** security, severity: low
```

****Descrição do problema / por que é explorável****

A conta viewer nasce com senha viewer e o PIN de display é 1234 (ambos com troca forçada no primeiro uso, documentados

****Evidência (arquivo:linha + trecho)****

```
- src/StorageManager.cpp:506-511 (viewer/viewer)  
- src/StorageManager.cpp:556 (PIN 1234 + setMustChangePin)  
- src/NetworkManager.cpp:97-98 (WiFi.softAP sem senha)
```

****Impacto****

Baixo, dado o controle de troca obrigatória e o login; risco residual se o operador não trocar.

****Sugestão de correção****

Opcional: WPA2 derivada do serial para o AP de setup; manter e testar as flags de troca forçada.

****Critérios de aceite****

```
- [ ] Avaliar WPA2 no AP sem quebrar o fluxo de recovery.  
- [ ] Confirmar que viewer/viewer e PIN 1234 continuam bloqueando navegação até a troca.  
--- FIM ISSUE 4 ---
```